

AWS IAM Interview Questions and Answers (3+ Years Experience) – Hinglish

1. What is IAM in AWS?

AWS IAM (Identity and Access Management) ek service hai jo users, groups, roles aur permissions manage karne ke liye use hoti hai. Isse hum control karte hain ki kaun AWS resources ko access kar sakta hai aur kya actions perform kar sakta hai.

2. Difference between IAM User and IAM Role?

IAM User

- Permanent identity hoti hai
- Username + password/access keys hote hain
- Mostly humans ke liye use hota hai

IAM Role

- Temporary permissions provide karta hai
- No permanent credentials
- EC2, Lambda aur cross-account access ke liye use hota hai

Example: EC2 ko S3 access dena ho → IAM Role attach karenge.

3. What is Least Privilege Principle?

Least privilege ka matlab: User ko sirf utni permissions dena jitni uske kaam ke liye required hain.

Ye AWS security best practice hai.

4. Difference between Managed Policy and Inline Policy?

Managed Policy

- Reusable policy
- Multiple users/groups/roles pe attach ho sakti hai
- AWS managed ya customer managed ho sakti hai

Inline Policy

- Directly ek hi user/role/group ke andar embedded hoti hai
 - One-to-one relationship
-

5. What are IAM Policies?

IAM policies JSON documents hoti hain jo permissions define karti hain.

Example:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "*"
    }
  ]
}
```

6. Difference between Authentication and Authorization?

Authentication

User kaun hai? (Login verification)

Authorization

User kya access kar sakta hai?

7. What is MFA in AWS?

MFA (Multi-Factor Authentication) extra security layer hai.

Login ke time:

- Password
- OTP/Auth app code

Dono required hote hain.

8. Why should we avoid using Root Account?

Root account ke paas full permissions hoti hain.

Best practices:

- Root account daily use nahi karna
 - MFA enable karna
 - Root credentials safely store karna
-

9. What is Cross-Account Access in AWS?

Jab ek AWS account ka user/role dusre AWS account ke resources access karta hai.

Mostly IAM Roles + Trust Policy use hoti hai.

10. What is Trust Relationship in IAM Role?

Trust relationship define karti hai ki kaun entity role assume kar sakti hai.

Examples:

- EC2 assume role
 - Another AWS account assume role
-

11. Difference between Identity-based and Resource-based Policies?

Identity-based Policy

- IAM user/group/role pe attach hoti hai

Resource-based Policy

- Resource pe directly attach hoti hai
 - Example: S3 Bucket Policy
-

12. What are Access Keys?

Programmatic access ke liye use hote hain:

- Access Key ID
- Secret Access Key

CLI, SDK aur automation scripts me use hote hain.

Best practice:

- Rotate regularly
 - Hardcode nahi karna
-

13. What is STS in AWS?

AWS STS (Security Token Service) temporary security credentials provide karta hai AWS resources access karne ke liye.

Temporary credentials include:

- Access Key ID
- Secret Access Key
- Session Token

Ye credentials limited time ke liye valid hote hain.

14. Why use STS?

Agar kisi user ya service ko temporary access dena ho AWS resources ka, then STS best choice hota hai.

Example:

- User A ko sirf 1 hour ke liye S3 access chahiye
 - Permanent access dena secure nahi hai
 - Isliye STS use karte hain
-

15. How STS Works

1. IAM Role create karte hain
2. Required permissions attach karte hain
3. User role assume karta hai

4. STS temporary credentials generate karta hai
 5. Credentials expire hone ke baad access automatically remove ho jata hai
-

16. Common STS APIs

AssumeRole

Most commonly used API.

Use cases:

- Cross-account access
- Temporary admin access
- EC2/Lambda role access

GetSessionToken

Existing IAM users ko temporary session credentials dene ke liye.

AssumeRoleWithSAML / WebIdentity

Federation login ke liye use hota hai.

Examples:

- Okta
 - Azure AD
 - Google Login
-

17. Difference between Permanent Access Keys and STS

Permanent Access Keys

- Security risk
- Hardcoded ho sakte hain
- Manual rotation required

STS Temporary Credentials

- Auto expire
 - More secure
 - No long-term credentials
 - Best for automation and cloud security
-

18. What is Federation in AWS IAM?

External identity providers (AD, Okta, Google) se login allow karna without creating IAM users.

19. Difference between Group and Role?

Group

- IAM users ka collection
- Common permissions assign karne ke liye

Role

- Temporary access
 - Services/applications/accounts assume karte hain
-

20. What is Explicit Deny and Allow?

AWS me: 1. By default sab kuch deny hota hai 2. Agar Allow mila → access mil sakta hai 3. Agar Explicit Deny mila → access immediately block ho jayega

Important Rule: Explicit Deny always wins over Allow.

21. Example of Explicit Deny

```
{
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:*",
      "Resource": "*"
    },
    {
      "Effect": "Deny",
      "Action": "s3:DeleteBucket",
      "Resource": "*"
    }
  ]
}
```

Meaning:

- User sab S3 actions kar sakta hai
- But bucket delete nahi kar sakta

Because Explicit Deny highest priority hota hai.

22. AWS Policy Evaluation Logic

AWS internally ye order follow karta hai:

1. Default Deny
2. Check Explicit Deny
3. Check Allow
4. Final Decision

If Explicit Deny exists: Access denied immediately.

23. Common Places where Explicit Deny comes from

- IAM Policies
 - S3 Bucket Policies
 - SCPs
 - Permission Boundaries
 - Session Policies
-

24. What are SCPs in AWS Organizations?

SCP (Service Control Policy) organization level pe maximum permissions define karti hai.

Even admin user bhi SCP restrictions bypass nahi kar sakta.

25. What are Permission Boundaries?

Maximum permissions limit define karti hain for IAM users/roles.

Delegated administration me useful.

26. Explain Policy Evaluation Logic

AWS evaluate karta hai:

- SCP
- Permission boundaries
- Session policies
- Identity policies
- Resource policies

Final decision:

- Explicit deny → deny
 - Allow required from applicable policies
-

27. Difference between AWS Managed and Customer Managed Policies?

AWS Managed

- AWS maintain karta hai

Customer Managed

- Hum create/manage karte hain
 - More customization
-

28. Real-Time Scenario: EC2 needs S3 access

Solution:

- IAM Role create karunga
- Required S3 permissions attach karunga
- EC2 instance ko role assign karunga

Access keys use nahi karunga because insecure hai.

29. Scenario: User can't access S3 bucket. How will you troubleshoot?

Check karunga: 1. IAM policy 2. Bucket policy 3. Explicit deny 4. SCPs 5. Permission boundaries 6. Region/resource ARN 7. CloudTrail logs

30. How do you secure IAM in production?

- MFA enable
- Least privilege
- Rotate keys
- Avoid root usage
- Use roles instead of access keys
- CloudTrail monitoring
- Password policy enforce
- IAM Access Analyzer use

31. What is IAM Access Analyzer?

Ye identify karta hai:

- Public access
- Cross-account access
- Unintended permissions

Security auditing ke liye useful hai.

Real-Time Interview Answer for STS

“Yes, if someone needs temporary access to AWS services, then AWS STS is the best choice. Using STS with AssumeRole, we can provide temporary security credentials with limited permissions and expiry time. This is more secure than sharing permanent access keys.”

Short Interview Version

“STS is used to provide temporary access to AWS resources using temporary security credentials. It is commonly used with IAM roles for secure and limited-time access.”